Vulnerability Assessment Report

Target: demo.testfire.net
(Altoro Mutal)

Prepared by Phenyo Pege

Contents

- Disclaimer
- Executive Summary
- Scope
- Findings
- Recommendation
- Remediation Priority

Disclaimer

This report is created and performed only for educational purposes on a website that is intended for security practice.

- website : http://demo.testfire.net

Executive Summary

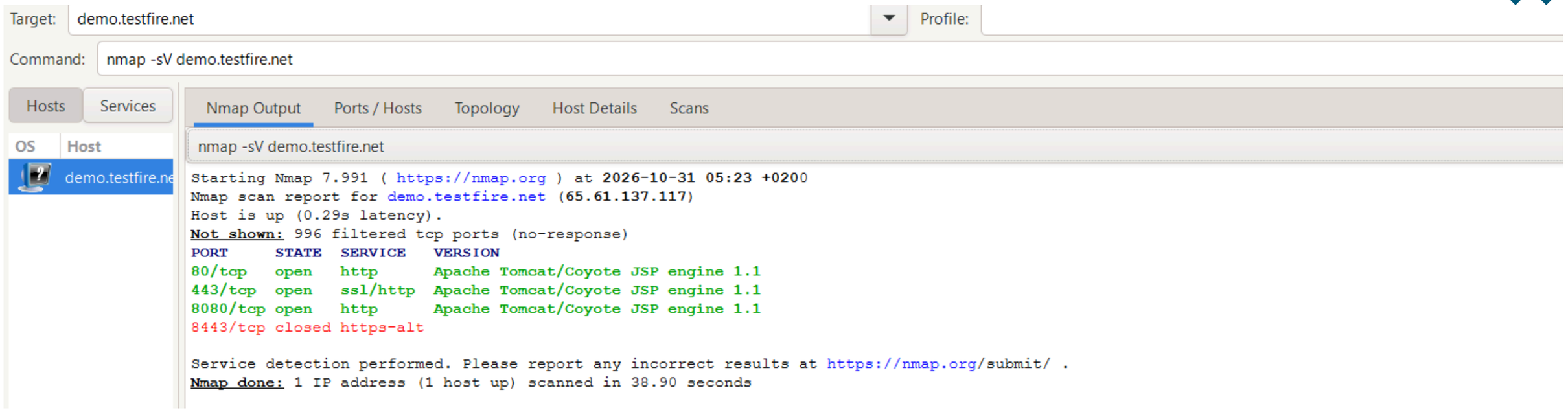
The assessment was done on a public banking demo application called Altoro Mutual, on the 30th - 31st October 2026. The testing covered port, service scanning, security headers, cookies and a passive ZAP scan were reviewed as allowed per scope. A total of 11 finding were identified, 1 high, 5 medium, 4 low and 1 informational

Scope

In scope: ports 80, 443 and 8080, Nmap scanned the 100 most common ports.
Method Used: Nmap, DevTools and ZAP passive
Out of scope: exploitation

- login bypass,
- brute force attacks and denial of service
- or any other exploitations that are not in the allowed scope

Findings - Evidence (Nmap)



The port and service scan shows 1000 most common ports, and shows three open web ports being:

- 80 - allows unencrypted traffic
- 443 - encrypted HTTPS
- 8080 - additional web service that most public sites do not need

The remaining ports (all 996) are filtered by a firewall, meaning there is a reduction in exposure

Recommedation:

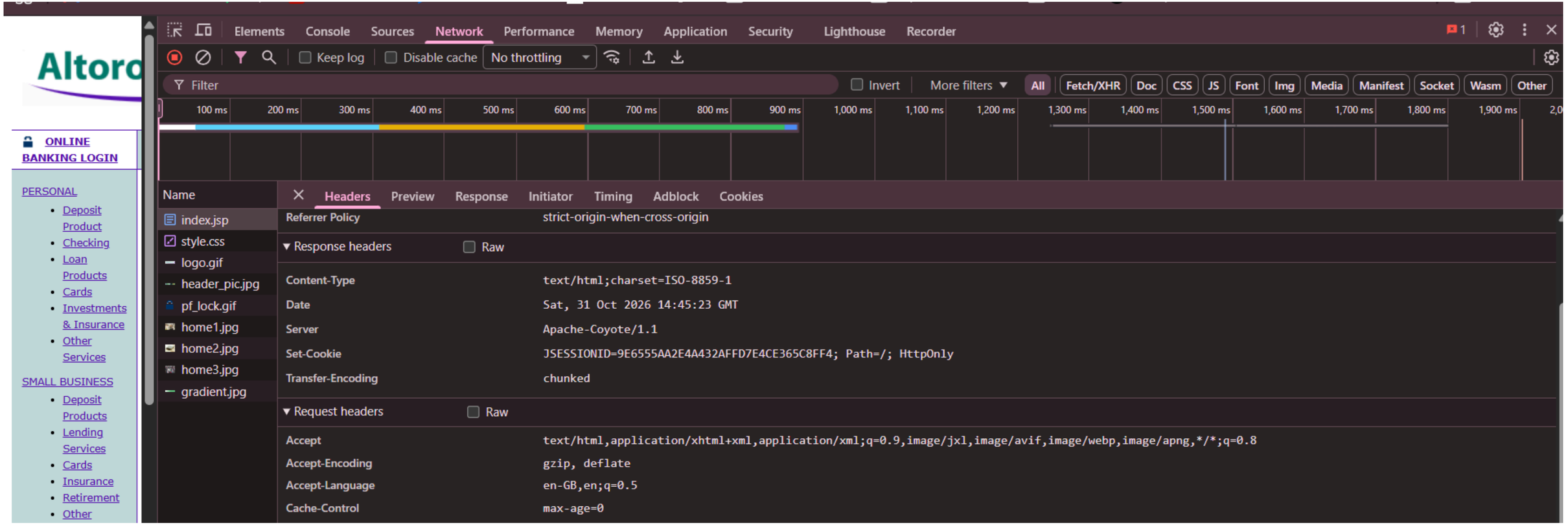
- Redirect all HTTP traffic to HTTPS.
- Close or restrict port 8080 to trusted IP addresses
- Configure the server to hide its software banner (as it reveals its software type to anyone who asks)

Findings Ratings (Nmap)

- Informational meaning there is no direct risk
- Low meaning its a minor weakness or info leak.
- Medium meaning it makes the attacks easier, an attack is enable under common conditions
- High meaning it could lead to data theft, or direct exploitation with major impacts

FINDINGS	RISK LEVEL	REASONS FOR SEVERITY
Extra web port 8080 - exposed to the internet	Medium	Secondary ports like this are often used for testing or administration
Port 80 is open - unencrypted HTTP	Medium	HTTP means visitors can use the site without encryption
Server software type is revealed (being Apache Tomcat)	Low	Expose to attackers what to research
Filtered ports by firewall	Positive or Informative	

Findings - Evidence (DevTools)



Findings - Headers & Cookies

The following **five** are headers a secure site should send, their absence makes the website more vulnerable and less secure.

ITEM	PRESENCE/ EVIDENCE	RISK LEVEL
Site serves over HTTP and does not redirect to HTTPS	Shown in ‘address bar’ as **not secure**	High
Content-Security Policy	Missing (Tells the browser which scripts are running, which limits malicious code)	Medium
X-Frame Options	Missing (Stops clickjacking)	Medium
Strict Transport Security	Missing Response Headers	Medium
X Content Type Options	Missing Response Headers	Low
Referrer Policy	Missing from the server (controls how much info is sent to other sites) Evidence: Response Headers	Low

Findings - Headers & Cookies (2)

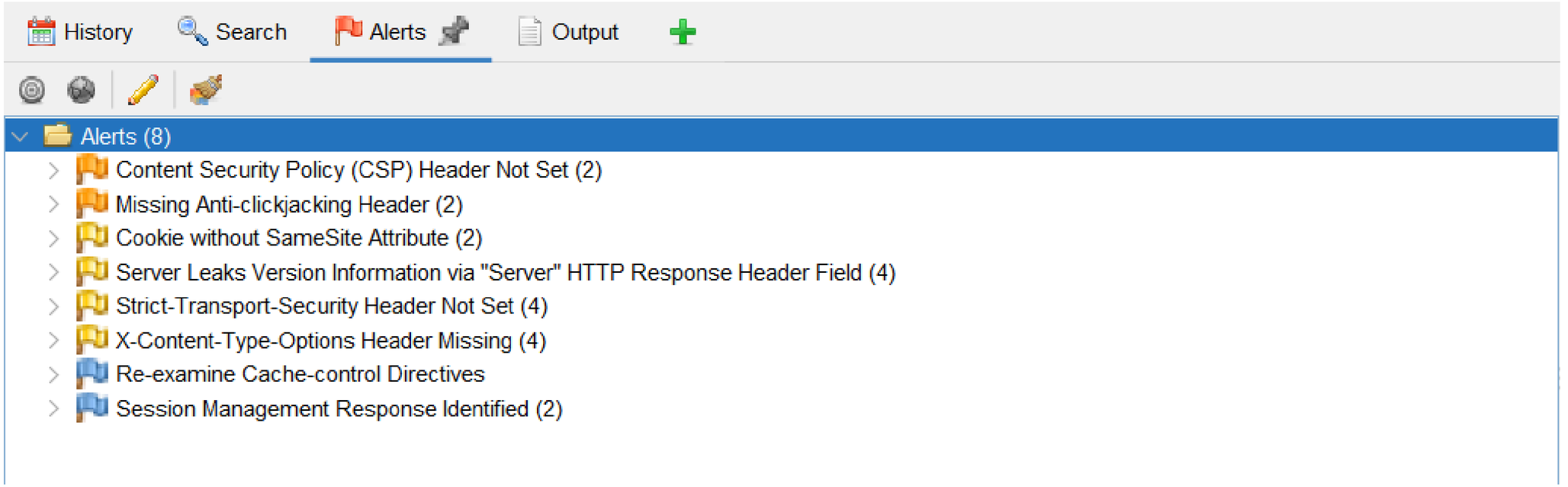
ITEM	PRESENCE/ EVIDENCE	RISK LEVEL
Session Cookie	Set-cookie header	Medium
Server Software is disclosed	Evidence is in the response headers & Nmap output	Low

Recommendation: To add the missing headers in the server configuration,

- for example: X Frame options: DENY

Session Cookie: The login session cookie (JSESSIONID) is marked HttpOnly but lacks the flags- Secure and SameSite. This missing headers combined with the weniste being reachable over HTTP, session theft is much easier.
Recommendation: Enable the flags on the session cookies and force HTTPS

Findings - ZAP (Passive Scan Results)



- Public pages were browsed.
- No attacks, logins or any form submissions were made

A TOTAL OF **8 ALERTS**

- 4 Low, 2 Medium and 2 Informational findings flagged, which are mostly missing security headers. The confirm what the manual DevTool check found.

Remedation Priotity & Steps

The first priority

- Redirect all HTTP traffic to HTTPS
- Add a “Strict Transport Security”

As demo.testfire.net is a banking site, allowing a HTTP means anyone that is on the same network can read or even steal a session cookies.

The second priority

- Close or restrict port 8080 (blocking the port at the firewall)
- Add the X Frame Options and Content Security Policy -

The third priotity

- Add a Referrer Policy and X Content Type Options (header response) and hide the server version banner